

# npm 280 fixture — 3-way 비교 결과

OSV-Scanner vs pkgsentinel vs Socket.dev API — 동일 fixture · 동일 metric

pkgsentinel · 7팀 · 2026-05-28 · 외부 도구 비교 측정

## 1. 측정 setup

- Dataset

DataDog malicious-software-packages-dataset 의 npm 280 패키지 (compromised\_lib 50 + malicious\_intent 200 + registry/benign 30).
- 도구 3종

(a) OSV-Scanner (Google OSS, lookup only) (b) pkgsentinel Claude full mode (c) Socket.dev API (상용)
- Metric

동일 confusion matrix — TP/FP/TN/FN → precision / recall / F1.
- Caveat 1

Socket 은 280 중 218 (78%) 만 측정 가능 — unpublish 된 침해 패키지 62개는 측정 불가 (\$5 참조).
- Caveat 2

pkgsentinel 은 1a 정정 (ERROR 6건 분모 제외) 적용 후 npm 만 재집계.

## 2. Overall metrics (npm 280 fixture)

| Tool                             | n   | TP  | FP  | TN | FN | Precision      | Recall         | F1             |
|----------------------------------|-----|-----|-----|----|----|----------------|----------------|----------------|
| OSV-Scanner (lookup only)        | 280 | 219 | 4   | 26 | 31 | 0.982          | 0.876          | 0.926          |
| <b>pkgsentinel (Claude full)</b> | 280 | 163 | 0 ★ | 30 | 87 | <b>1.000 ★</b> | 0.652          | 0.789          |
| Socket.dev API                   | 218 | 178 | 2   | 26 | 12 | 0.989          | <b>0.937 ★</b> | <b>0.962 ★</b> |

★ : 해당 metric 의 단일 최우수. pkgsentinel = precision 챔피언 (FP 0) Socket = recall / F1 챔피언.

## 3. Trade-off — Precision vs Recall 시각화

세 도구가 명시적으로 다른 trade-off 디자인을 보여줌:

### Precision

|             |             |       |
|-------------|-------------|-------|
| OSV-Scanner | <div></div> | 0.982 |
| pkgsentinel | <div></div> | 1.000 |
| Socket.dev  | <div></div> | 0.989 |

### Recall

|             |             |       |
|-------------|-------------|-------|
| OSV-Scanner | <div></div> | 0.876 |
| pkgsentinel | <div></div> | 0.652 |
| Socket.dev  | <div></div> | 0.937 |

→ pkgsentinel = precision 우선 보수 디자인 (verdict\_rules 의 5가지 정책). Socket = recall 우선 (행위 신호 다수 + LLM 결합). OSV = 단순 lookup baseline.

## 4. by source 분석

### 4.1 compromised\_lib (Shai-Hulud 등 사건 침해, n=50)

| Tool               | TP | FN | Recall         | 주석             |
|--------------------|----|----|----------------|----------------|
| OSV-Scanner        | 40 | 10 | 0.800          | advisory 8개 누락 |
| <b>pkgsentinel</b> | 42 | 8  | <b>0.840 ★</b> | OSV 대비 +4%p    |
| Socket.dev (n=36)  | 32 | 4  | 0.889          | 14개 측정 불가      |

→ pkgsentinel 이 공식 advisory lookup (OSV) 보다 +4%p 우월. 행위 분석이 advisory 누락분을 보완.

### 4.2 malicious\_intent (typosquat / slop, n=200)

| Tool               | TP  | FN | Recall         | 주석                      |
|--------------------|-----|----|----------------|-------------------------|
| OSV-Scanner        | 179 | 21 | 0.895          | typosquat advisory 잘 잡음 |
| <b>pkgsentinel</b> | 121 | 79 | <b>0.605</b>   | 우리 약점 — 이름<br>휴리스틱 약함   |
| Socket.dev (n=154) | 146 | 8  | <b>0.948 ★</b> | 70+ 행위 신호 강력            |

→ pkgsentinel 약점 명확히 노출. typosquat 은 \*이름 휴리스틱\*이 결정적인데 우리 verdict 는 \*행위 분석\* 위주. 개선 plan: stage 01 의 typosquat\_candidates 를 verdict 에 강하게 반영 (Task #26).

4.3 registry (정상 인기 패키지, n=30)

| Tool               | FP         | TN | FPR            | 주석                   |
|--------------------|------------|----|----------------|----------------------|
| OSV-Scanner        | 4          | 26 | 0.148          | deprecated 정상 패키지 매칭 |
| <b>pkgsentinel</b> | <b>0 ★</b> | 30 | <b>0.000 ★</b> | zero false positive  |
| Socket.dev (n=28)  | 2          | 26 | 0.074          | 보수적 알고리즘 — 일부 의심     |

→ pkgsentinel 만 zero FP. verdict\_rules 의 LLM BENIGN 덮어쓰기 정책 + max(MAL conf) ≥ 0.85 정책의 결과.

5. Socket 의 측정 한계 — unpublish 침해 패키지 분석 불가

Socket 은 fixture 280 중 218 (78%) 만 측정 가능, 62 (22%) 는 측정 불가:

- compromised\_lib: 50 → 36 (14 unpublish)
- malicious\_intent: 200 → 154 (46 unpublish / 신규 / 큐레이션 외)
- registry: 30 → 28 (정상이지만 일부 응답 실패)

→ Socket 의 0.937 recall 은 \*측정 가능 표본\* 한정. 280 전체 단위로 보면 Socket 도 178/280 = 0.636 (pkgsentinel 0.582 와 비슷).

★ 핵심: 사후 unpublish 된 침해 패키지는 \*상용 도구도 분석 불가\*. pkgsentinel 은 archive 보존 (DataDog dataset) 분석 능력으로 전체 표본 측정 가능 — 사건 후 사라진 패키지에 대한 forensic 분석 은 우리 도구의 차별점.

6. 결론 — pkgsentinel 의 차별 포지션

도구별 명시적 trade-off 디자인:

| 측면                     | 우리 위치         | 의미                                        |
|------------------------|---------------|-------------------------------------------|
| Precision (FP 0)       | ★ 최고 (1.000)  | 정상 패키지 한 건도 잘못 안 잡음                       |
| compromised_lib recall | OSV 대비 +4%p   | 공식 advisory 누락분을 행위 분석으로 보완               |
| Archive 분석             | ★ 유일          | Socket 도 못 함. unpublish forensic 가능       |
| typosquat recall       | 약점 (0.605)    | 개선 plan 식별 (Task #26)                     |
| Socket 대비 recall       | 약함 (단, 표본 다름) | 매니페스트 도입 시 trade-off 개선 가능 (Task C 측정 예정) |

한 줄 요약

pkgsentinel = precision 우선 보수 디자인 + archive 분석 능력 + 공식 advisory 보완. Socket = recall 우선 상용 도구 + 측정 불가 영역 존재. OSV = 단순 lookup baseline.

원본 측정 데이터: scripts/eval\_real\_data/results\_osv\_scanner.json (OSV), scripts/eval\_real\_data/results\_claude\_full\_v2.json (pkgsentinel, 1a 정정), scripts/eval\_real\_data/results\_socket\_npm.json (Socket).